Passive Vulnerability Assessment Report for testphp.vulnweb.com

Assessment Type: Read-Only / Passive Analysis
Date: October 2026
Prepared for: Future Interns – Cyber Security Task 1 (2026)
Scope: Public-facing pages, headers & configuration only

Confidential - Educational Purpose Only

Gemini Notebook

The site lacks fundamental security hygiene but requires no complex code rewrites.

This read-only assessment revealed critical configuration gaps that increase the risk of successful attacks. All findings are infrastructure-level issues resolvable via standard server configuration changes.



Gemini Notebook

Passive reconnaissance captures vulnerabilities by observing **traffic without launching attacks.**

The Rules of Engagement



What We Did

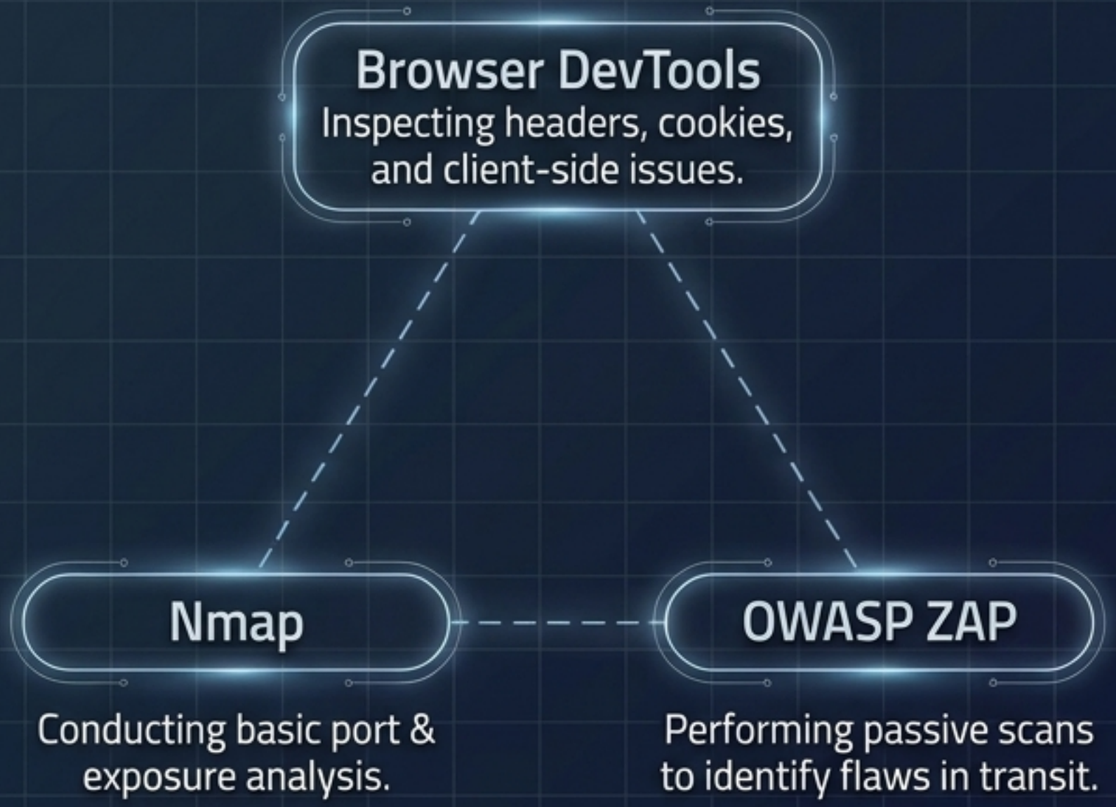
- Public-facing pages only
- Passive scanning
- Header checks



What We Didn't Do

- No login bypass
- No brute force
- No Denial-of-Service

The Passive Reconnaissance Triad



Gemini Notebook

Five configuration gaps expose the infrastructure to high-probability attacks.

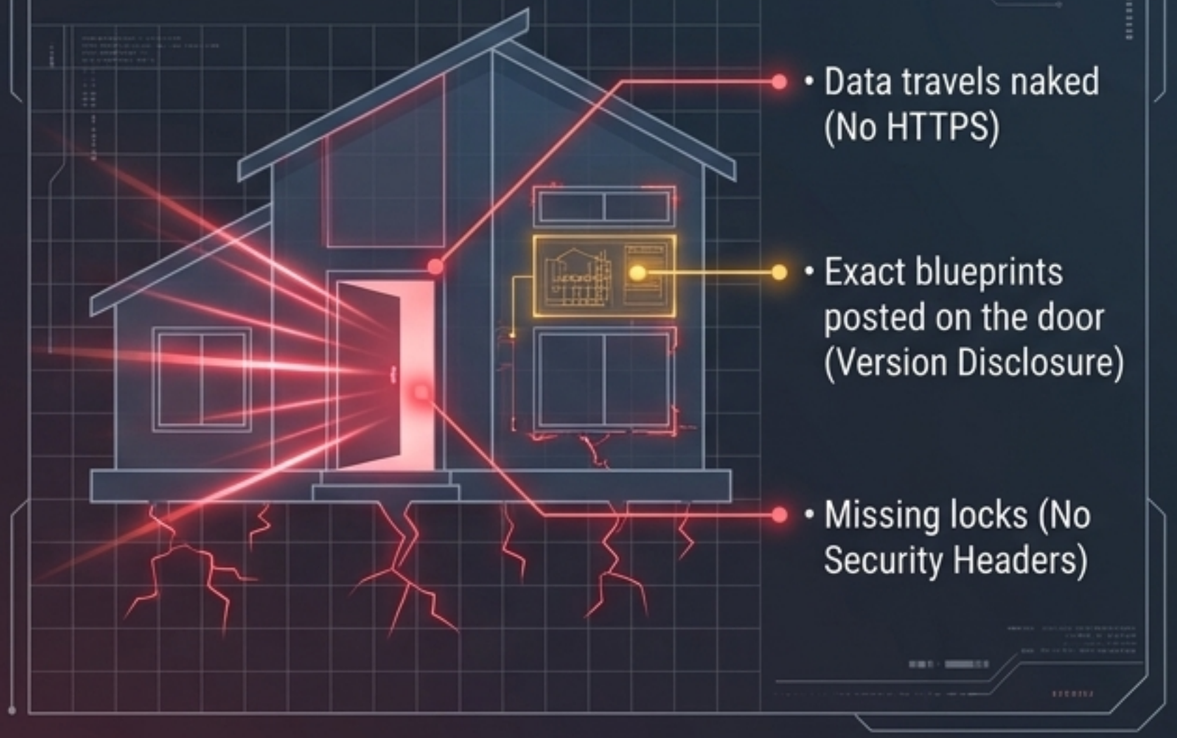
Vulnerability Category	Risk Level	Business Impact
Outdated / End-of-Life Software	High Risk	Permanent risk of unpatched exploits.
No HTTPS (Cleartext Communication)	High Risk	Interception of data on public networks.
Missing Critical Security Headers.	High Risk	Browser unable to block XSS and clickjacking.
Server & Technology Version Disclosure.	Medium Risk	Attackers gain an exact exploitation roadmap.
Information Disclosure via Headers.	Medium Risk	Unnecessary tech stack exposure accelerates attacks.

High-risk issues must be prioritized to close critical attack vectors.

Gemini Notebook

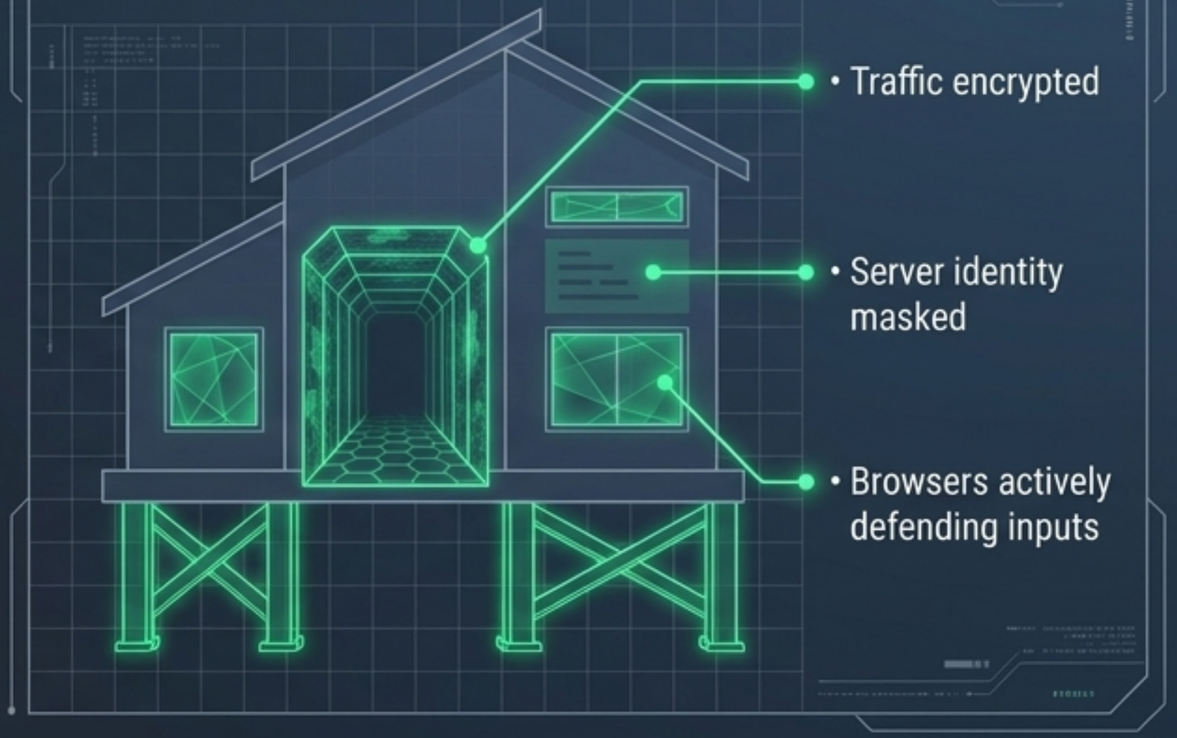
The Attack Surface: An open front door requires no lockpicks.

Current State



- Data travels naked (No HTTPS)
- Exact blueprints posted on the door (Version Disclosure)
- Missing locks (No Security Headers)

Secure State



- Traffic encrypted
- Server identity masked
- Browsers actively defending inputs

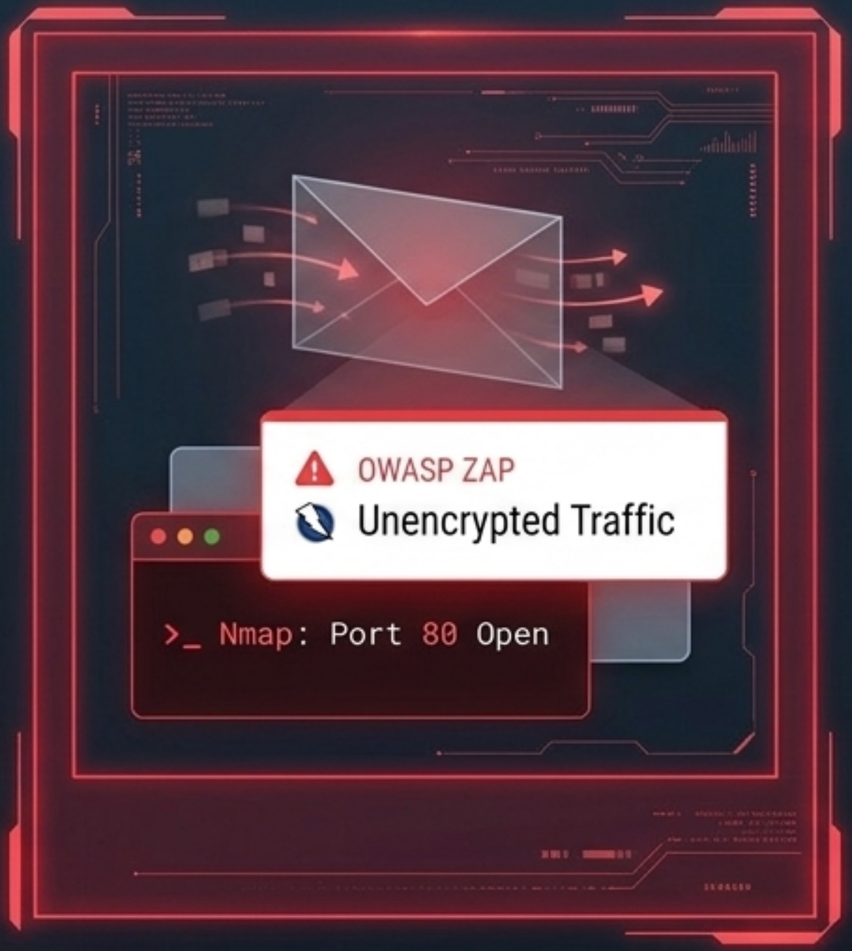
Gemini Notebook

Unencrypted HTTP traffic exposes all internal and user data to network interception.

High Risk

The total absence of HTTPS encryption.

The entire site is served over HTTP.





All data (credentials, sessions) travels in clear text, vulnerable on public Wi-Fi.

Browsers will penalize the site with a ‘Not Secure’ warning, damaging user trust.

Gemini Notebook

End-of-Life infrastructure creates a permanent, unpatchable vulnerability window.

The Vulnerability: The website runs on PHP 5.6.40 and Nginx 1.19.0. Both versions are deprecated.



Business Impact: Any newly discovered vulnerability becomes a permanent feature of the website, leaving it perpetually open to automated exploitation because vendors will never issue security updates.

Gemini Notebook

Missing security headers force user browsers to blindly trust malicious inputs.

The Vulnerability:

Absence of critical headers including Content-Security-Policy (CSP), Strict-Transport-Security (HSTS), X-Frame-Options, and X-Content-Type-Options.



Business Impact:

The site is highly susceptible to Cross-Site Scripting (XSS), clickjacking, and content-type confusion. Attackers can manipulate the browser into executing hostile actions on behalf of the user.

OWASP ZAP Passive Scan Alerts

Alert	Risk Level	Description
Missing Anti-clickjacking Header	High	X-Frame-Options or CSP missing.
Missing X-Content-Type-Options Header	High	Prevents MIME-sniffing.
Missing HSTS Header	High	Enforces secure connections.
Missing Content-Security-Policy Header	High	Mitigates XSS attacks.

Gemini Notebook

Explicit version disclosure provides attackers with a precise exploitation roadmap.

The Concept



The Vulnerability: The server openly returns headers identifying the exact technology stack. This minimizes the reconnaissance phase for an attacker, allowing them to search vulnerability databases for exact exploits.

The Evidence



Gemini Notebook

Remediation occurs entirely at the infrastructure layer, preserving the application code.

Server / Infrastructure Layer
(Nginx / PHP Engine)



Fixes applied here.
(SSL Installation, Version Upgrades, Header Injection).

Application Layer
(testphp)

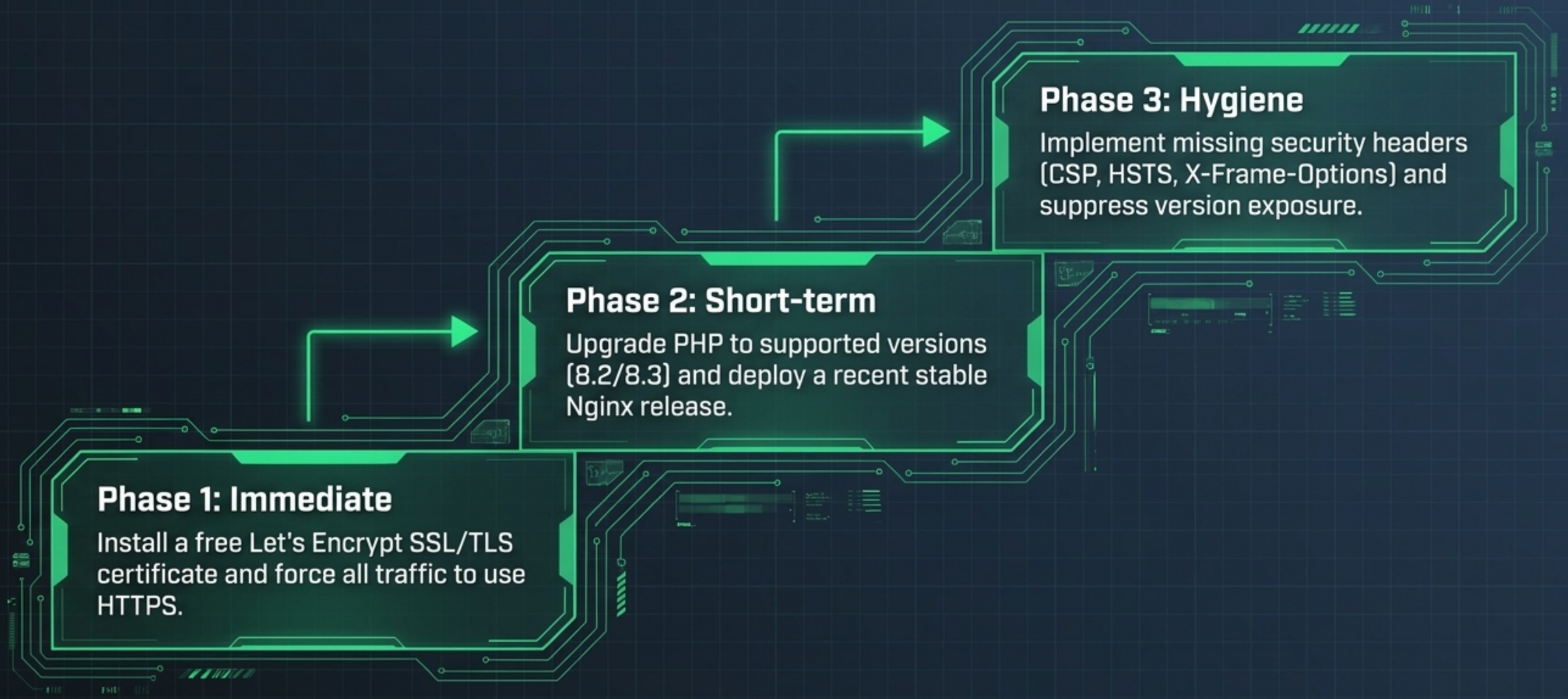


No costly code rewrites required.

By resolving configuration and hygiene issues at the server level, we **drastically reduce the attack surface** without interrupting application functionality or requiring **software engineering** hours.

Gemini Notebook

A phased implementation timeline hardens the perimeter using standard IT operations.



Gemini Notebook

Standardizing server configuration transforms a high-risk liability into a hardened asset.



The assessment confirms that while testphp.vulnweb.com currently operates with critical exposure, the vulnerabilities are strictly architectural hygiene. Executing the remediation roadmap will definitively secure data in transit, defend against browser-based attacks, and establish a resilient, professional security posture.

Assessment complete. Clear for operational handoff.

Gemini Notebook